

Разбор тезисов консультации по информационному праву

11_Разбор_консультации_по_информационному_праву.md

Дата: 02.09.2026.

Восемь тезисов, полученных на очной консультации со специалистом по информационному праву, развёрнуты до полных формулировок и проверены по нормам. Проверка выходит за пределы 152-ФЗ: затронуты 149-ФЗ, 406-ФЗ, 54-ФЗ, 422-ФЗ, ГК РФ, ПП РФ № 1119 и приказы ФСТЭК.

Обозначения: [ПОДТВЕРЖДЕНО] — норма найдена и однозначна; [ЧАСТИЧНО] — верно с оговорками; [УТОЧНИТЬ] — тезис записан неполно, нужен повторный вопрос.

Сводка: что меняется в проекте

№	Тезис	Оценка	Влияние
1	Специалист по ИБ в штате	[ПОДТВЕРЖДЕНО]	Сильный аргумент за ООО, усиливает документ 06
2	Договор только письменный, отдельный для каждого	[ЧАСТИЧНО]	Подтверждает отказ от оферты и модель «только по приглашениям»
3	ЭЦП можно, но не физлицам	[УТОЧНИТЬ]	—
4	Пакет документов зависит от лица	[ПОДТВЕРЖДЕНО]	Уже учтено в ГЛАВНОЕ
5	ККТ при расчётах через физлиц	[ПОДТВЕРЖДЕНО]	Онлайн-оплата требует фискализации
6	Смотреть приказы ФСТЭК	[ПОДТВЕРЖДЕНО]	Перечень ниже
7	Госуслуги, привязка домена	[ПОДТВЕРЖДЕНО]	Прямо касается системы авторизации — новая норма, ранее не разобранная
8	Разные данные — разный режим	[ПОДТВЕРЖДЕНО]	Смежные тайны за пределами 152-ФЗ

Тезис 1. Ответственный за безопасность персональных данных должен быть работником организации

Развёрнутая формулировка. Организация, обрабатывающая персональные данные, обязана назначить должностное лицо (работника), ответственное за обеспечение безопасности персональных данных в информационной системе. Это отдельное лицо, не совпадающее с ответственным за организацию обработки.

Оценка: [ПОДТВЕРЖДЕНО].

[ЗАКОН] Постановление Правительства РФ от 01.11.2012 № 1119 требует для **3-го уровня защищённости** (помимо требований к УЗ-4), чтобы «было назначено должностное лицо (работник), ответственный за обеспечение безопасности персональных данных в информационной системе».

Критически важно не путать две разные роли — их регулируют разные нормы с разным кругом адресатов:

Роль	Норма	Кто обязан
Ответственный за организацию обработки ПДн	П. 1 ч. 1 ст. 18.1, ч. 1 ст. 22.1 152-ФЗ	Только юридические лица
Ответственный за обеспечение безопасности ПДн в ИС	ПП РФ № 1119, требования к УЗ-3 и выше	Любой оператор , чья ИСПДн имеет УЗ-3 или выше

Из этого следует вывод, которого нет в текущем комплекте документов: **освобождение физического лица от назначения ответственного за организацию обработки (зафиксировано в ГЛАВНОЕ_что_делать_и_что_проверить.md) не распространяется на ответственного за безопасность**. Вторая обязанность возникает из уровня защищённости, а не из организационно-правовой формы.

Проект планируется под УЗ-3 (см. 04, раздел 5.2). Следовательно, требование применимо.

Что это означает для выбора формы. [СПОРНО] Формулировка «должностное лицо (работник)» предполагает наличие трудовых отношений. Самозанятый лишён права нанимать работников (ч. 7 ст. 2 ФЗ-422). Возможные прочтения:

- *мягкое:* оператор — физическое лицо сам исполняет эту функцию, назначение оформляется его собственным решением;
- *консервативное:* требование предполагает организацию с работником, и для физического лица оно неисполнимо в принципе.

[РЕКОМЕНДАЦИЯ] Это **третий по значимости аргумент за регистрацию ООО** после лимита дохода и неограниченной имущественной ответственности (документ 06). Ранее он не назывался. Вопрос стоит вернуть консультанту в конкретной формулировке: «может ли оператор — физическое лицо назначить ответственным за обеспечение безопасности ПДн самого себя, и чем это оформляется».

Об аутсорсинге. Привлечение внешнего специалиста по договору переводит отношения в оказание услуг по защите информации третьему лицу, что требует у исполнителя лицензии ФСТЭК на ТЗКИ (ПП РФ № 79) — см. ЮРИДИЧЕСКИЙ_АНАЛИЗ.md, п. Б.11. Внешний подрядчик без лицензии проблему не закрывает.

Тезис 2. Договор поручения оформляется письменно, отдельно с каждым оператором; универсальная форма не годится

Развёрнутая формулировка. Поручение обработки персональных данных оформляется договором в письменной форме. Единый универсальный документ для всех заказчиков недопустим — с каждым оператором заключается отдельный договор, отражающий состав именно его данных и операций.

Оценка: [ЧАСТИЧНО] — вывод верный, обоснование требует уточнения.

[ЗАКОН] Ч. 3 ст. 6 152-ФЗ: обработка по поручению осуществляется на основании заключаемого договора. В поручении **должны быть определены**: перечень персональных данных, перечень действий (операций), обязанность соблюдения конфиденциальности, требования к защите по ст. 19, обязанность уведомлять оператора о фактах неправомерной или случайной передачи.

По форме. [СПОРНО] Утверждение «только в печатном виде» строже закона. Ст. 160 и ст. 434 ГК РФ приравнивают электронный документ, подписанный электронной подписью, к письменной форме. Печатный экземпляр обязателен не по 152-ФЗ, а по практике корпоративных закупок и по требованиям служб безопасности крупных заказчиков.

По универсальности — здесь тезис силён. Требование ч. 3 ст. 6 определить *перечень* персональных данных и *перечень* действий по своей природе конкретно: у разных заказчиков разный состав документов и разный набор операций. Универсальная оферта эти перечни неизбежно размывает до формулировок вида «любые персональные данные, содержащиеся в передаваемых документах», что требованию об определённости не отвечает.

На практике оферты-поручения встречаются, поэтому категорического запрета нет. Но риск переносится на оператора: при проверке размытый перечень читается как отсутствие определённого поручения.

Связь с архитектурой. Этот тезис независимо подтверждает вывод документов 09 и 10: конструкция договора присоединения для self-serve (помеченная в 09 как [СПОРНО]) ненадёжна. **Модель «регистрация только по приглашению, отдельный договор с каждым аккаунтом» получает второе независимое обоснование** — теперь не только от режима обработки, но и от требований к форме поручения.

Тезис 3. Электронная подпись допустима, но не для физических лиц

Оценка: [УТОЧНИТЬ] — тезис записан неполно, однозначно восстановить смысл нельзя.

Утверждение в буквальном прочтении неверно: усиленная квалифицированная электронная подпись физического лица существует, и документ 04 прямо предполагает её использование для электронной подачи уведомления в Роскомнадзор.

Правдоподобные прочтения, каждое из которых имеет смысл:

1. **Порядок получения различается.** Юридические лица и ИП получают УКЭП в удостоверяющем центре ФНС бесплатно; физическое лицо — только в аккредитованном коммерческом УЦ и за плату.
2. **Машиночитаемая доверенность.** При подписании от имени организации сотрудником требуется МЧД; для физического лица конструкция иная.
3. **Практика контрагентов.** Корпоративные системы ЭДО нередко не принимают подпись физического лица как сторону договора, требуя ИП или юрлицо.

[РЕКОМЕНДАЦИЯ] Вернуть вопрос консультанту в формулировке: «что именно недоступно физическому лицу — получение УКЭП, подписание договора поручения электронной подписью, или приём такой подписи контрагентами».

Тезис 4. Состав обязательного пакета документов зависит от организационно-правовой формы

Оценка: [ПОДТВЕРЖДЕНО] — совпадает с уже зафиксированным в ГЛАВНОЕ_Что_делать_и_что_проверить.md.

[ЗАКОН] Для физического лица **не возникают**: обязанность назначить ответственного за организацию обработки (п. 1 ч. 1 ст. 18.1, ч. 1 ст. 22.1 — норма прямо адресована юридическим лицам) и обязанность издавать локальные акты (п. 2 ч. 1 ст. 18.1 — та же оговорка).

Возникают независимо от формы: уведомление в Роскомнадзор (ст. 22), публикация политики при сборе через интернет (ч. 2 ст. 18.1), весь блок мер по ст. 19, обязанности по ст. 21 (сроки реагирования).

Важная поправка по итогам тезиса 1: список освобождений для физического лица **не включает** ответственного за обеспечение безопасности ПДн — эта обязанность вытекает из ПП РФ № 1119 и уровня защищённости, а не из организационно-правовой формы.

Тезис 5. При расчётах с физическими лицами без контрольно-кассовой техники обойтись нельзя

Развёрнутая формулировка. Приём оплаты от физических лиц требует применения контрольно-кассовой техники и выдачи фискального чека. Самозанятый — исключение: он формирует чек в приложении «Мой налог» и ККТ не применяет.

Оценка: [ПОДТВЕРЖДЕНО].

[ЗАКОН] Федеральный закон от 22.05.2003 № 54-ФЗ — обязанность применять ККТ при расчётах. Плательщики налога на профессиональный доход от применения ККТ освобождены; чек формируется в приложении «Мой налог» (ФЗ от 27.11.2018 № 422-ФЗ). Освобождение сохраняется и для ИП на НПД.

Что это значит для системы биллинга (документ 10):

Сценарий	ККТ	Комментарий
Самозанятый, оплата от юрлиц по счёту	не нужна	чек из «Мой налог» по каждому платежу
ООО, безналичная оплата от юрлиц по счёту	не нужна	расчёты между организациями без предъявления электронного средства платежа
ООО или ИП, оплата картой от физического лица	нужна	требуется фискализация — облачная касса

[РЕКОМЕНДАЦИЯ] Это **дополнительное основание** держать онлайн-оплату отдельным этапом (раздел 8 документа 10). Платёжная интеграция — не только эквайринг: она тянет за собой фискализацию, чеки по 54-ФЗ и отчётность. Провайдеры (ЮKassa, Робокасса) предоставляют облачную кассу, но это отдельный договор и отдельные затраты.

Текущая модель — ручная выдача квот по договору с юридическим лицом — от требований ККТ свободна.

Тезис 6. Изучить приказы ФСТЭК России

Оценка: [ПОДТВЕРЖДЕНО]. Перечень применимых актов:

Акт	Предмет	Применимость
Приказ ФСТЭК от 18.02.2013 № 21	Состав и содержание мер защиты ПДн в ИСПДн (ред. от 14.05.2020)	Основной документ проекта
Приказ ФСТЭК от 11.02.2013 № 17	Защита информации в государственных информационных системах	Только при появлении государственных заказчиков
Приказ ФСТЭК от 25.12.2017 № 239	Обеспечение безопасности значимых объектов КИИ	Косвенно — если заказчик является субъектом КИИ
Методика оценки угроз безопасности информации ФСТЭК от 05.02.2021	Порядок разработки модели угроз	Обязательна для модели угроз
Банк данных угроз ФСТЭК (bdu.fstec.ru)	Каталог угроз и уязвимостей	Источник данных для модели угроз

Приказ ФСБ России от 10.07.2014 № 378 применяется дополнительно при использовании СКЗИ.

Приказ № 21 и методика 2021 года уже упомянуты в `юридический_АНАЛИЗ.md`; приказы № 17 и № 239 в комплекте не разобраны.

Тезис 7. Госуслуги и привязка домена — установить, как и зачем

Развёрнутая формулировка (реконструкция). Речь идёт о требовании к способу авторизации пользователей на российских сайтах, введённом в 2023 году: авторизация допускается только через ограниченный перечень систем, включая ЕСИА (Госуслуги).

Оценка: [ПОДТВЕРЖДЕНО] — и это норма, которой в комплекте документов нет вообще.

[ЗАКОН] Федеральный закон от 31.07.2023 № 406-ФЗ внёс изменения в ст. 10 Федерального закона от 27.07.2006 № 149-ФЗ «Об информации, информационных технологиях и о защите информации». Владелец сайта или информационной системы, являющийся российским юридическим лицом либо гражданином РФ и осуществляющий деятельность в интернете на территории РФ, обязан проводить авторизацию пользователей, находящихся на территории РФ, одним из способов:

1. по абонентскому номеру российского оператора подвижной радиотелефонной связи;
2. через ЕСИА (Единая система идентификации и аутентификации — Госуслуги);
3. через ЕБС (Единая биометрическая система);
4. через **иную информационную систему**, владельцем которой является гражданин РФ или российское юридическое лицо.

Норма действует с 01.12.2023.

Оценка спроектированной схемы авторизации (документ 10). Вход по паре «адрес электронной почты + пароль» в собственной системе подпадает под способ 4 — при условии, что владелец системы является российским лицом. Для проекта это выполняется.

[СПОРНО] Практическая неопределённость сохраняется в отношении **адресов на иностранных почтовых сервисах**. Публичная дискуссия вокруг 406-ФЗ («запрет авторизации через

иностранную электронную почту») касается именно случая, когда подтверждение доступа уходит на gmail и аналогичные сервисы. Разъяснения профильных объединений существуют, но единой правоприменительной позиции нет.

[РЕКОМЕНДАЦИЯ] Для B2B-модели риск ограничен: пользователи — работники организаций-заказчиков, как правило с корпоративными адресами в российских доменах. Меры снижения риска, в порядке возрастания стоимости:

1. в договоре и при выдаче приглашения требовать корпоративный адрес заказчика, не публичный почтовый сервис;
2. добавить подтверждение по абонентскому номеру как второй способ (прямо назван в норме первым);
3. интеграция с ЕСИА — тяжело, оправдано только при работе с государственными заказчиками.

Первый пункт реализуется проверкой домена при приёме приглашения и стоит несколько строк кода.

Про «привязку домена». [УТОЧНИТЬ] Точный смысл восстановить не удалось. Правдоподобные варианты: подтверждение владения доменом при интеграции с ЕСИА; регистрация сведений о сайте при подаче уведомления в Роскомнадзор; подтверждение домена в личном кабинете организации. Вопрос вернуть консультанту.

Тезис 8. Разные категории данных обрабатываются по-разному

Оценка: [ПОДТВЕРЖДЕНО]. Внутри 152-ФЗ действуют четыре самостоятельных режима:

Категория	Норма	Режим
Обычные ПДн	Ст. 6	Обработка при наличии любого из оснований ч. 1
Специальные категории	Ст. 10	Обработка запрещена , кроме закрытого перечня ч. 2
Биометрические	Ст. 11	Как правило письменное согласие; ЕБС
Общедоступные	Ст. 8	Облегчённый режим

Существеннее то, что находится за пределами 152-ФЗ. Один и тот же документ может одновременно подпадать под режим иной охраняемой тайны, и требования складываются, а не заменяют друг друга:

Тайна	Норма	Когда возникает в продукте
Врачебная	Ст. 13 ФЗ от 21.11.2011 № 323-ФЗ	Медицинские документы — детекторы MED_ICD, MED_RECORD
Банковская	Ст. 26 ФЗ от 02.12.1990 № 395-1	Выписки, реквизиты счетов — детектор BANK_ACCOUNT
Налоговая	Ст. 102 НК РФ	Налоговая отчётность контрагентов

Тайна	Норма	Когда возникает в продукте
Адвокатская	Ст. 8 ФЗ от 31.05.2002 № 63-ФЗ	Документы от юридических фирм
Коммерческая	ФЗ от 29.07.2004 № 98-ФЗ	Договоры с условиями о цене

[РЕКОМЕНДАЦИЯ] Договорный запрет (документ 04, раздел 5.2, вариант С) следует формулировать не только через специальные категории ПДн, но и через перечень охраняемых тайн. Иначе запрет закрывает медицинские документы и не закрывает, например, адвокатские, где режим не мягче.

Что делать по итогам

№	Действие	Приоритет
1	Вернуть консультанту три уточняющих вопроса: тезис 1 (может ли физлицо назначить себя), тезис 3 (что именно недоступно физлицу), тезис 7 (смысл привязки домена)	Высокий
2	Внести в документ 06 третий аргумент за ООО — ответственный за безопасность ПДн по ПП № 1119	Высокий
3	Проверка домена корпоративной почты при приёме приглашения	Средний
4	Расширить договорный запрет с специальных категорий до перечня охраняемых тайн	Средний
5	Разобрать приказы ФСТЭК № 17 и № 239 на применимость	Низкий

Источники

- [Федеральный закон от 31.07.2023 № 406-ФЗ — официальное опубликование](#)
- [Федеральный закон от 31.07.2023 № 406-ФЗ — ГАРАНТ](#)
- [Разъяснения кластера «РАЭК / Privacy & Legal Innovation» по закону об авторизации](#)
- [Постановление Правительства РФ от 01.11.2012 № 1119 — ГАРАНТ](#)
- [ПП РФ № 1119, пункт 13\(в\) — разбор требования](#)
- [Ст. 6 152-ФЗ «Условия обработки персональных данных» — ГАРАНТ](#)
- [Ст. 21 152-ФЗ — сроки реагирования, КонсультантПлюс](#)
- [Касса для самозанятых: когда нужна ККТ — Главная книга](#)
- [Приём платежей от физических лиц и выдача чеков](#)